Assignment 11 - Ethics, Privacy, Security and Licensing Statement

Ethics Statement (version 1.0, November 11, 2026)

Team: Allison Oh, Aditya Pawar · Documentation owner: Allison Oh · Advisors: Jillian Aurisano, Todd Liebermann
Source: https://github.com/AllyOI/model-recommend/blob/main/Ethics_Statement.md · Senior Design 1, Fall 2026

Ethics, Privacy, Security and Licensing Statement — Model Recommend

Project: Model Recommend (Concentrate AI) **Team:** Allison Oh, Aditya Pawar **Owner:** Allison Oh (documentation owner). Section checks: Aditya Pawar for the Recommendation Server, LLM adapter and Authentication; Allison Oh for the Recommendation Client, Report Store, Notifications and Configuration. **Version:** 1.0 (2026-11-11). Traces to *Requirements_Document.md* v1.0, *Technical_Specification.md* v1.1 and *Test_Plan.md* v1.0.

What the system asks people to trust us with. A client company's IT security reviewer trusts us to send its prompts only to vendors it approved (US-04). Its product manager trusts us with a task description that can contain customer data (CON-02), and trusts the ranking to be honest about cost (CON-03). Concentrate AI trusts us with vendor API keys and spend (CON-01). The sections below apply the ACM Code of Ethics to those promises:

- **1.2 Avoid harm** and **1.6 Respect privacy:** the Privacy summary.
- **2.9 Design and implement systems that are robustly and usably secure:** the Security summary.
- **1.5 Respect the work required to produce new ideas** and **2.3 Know and respect existing rules:** the Licensing summary and Attribution list.
- **1.3 Be honest and trustworthy:** the AI-use disclosure.

Diversity and cultural limits we state rather than hide:

- Briefs, sanitization rules and the grader rubric assume English (AS-05). A non-English brief can be graded unfairly, so the Client will warn when it detects a non-English task description (proposed for T12).
- Phone-number redaction covers the formats in the 200-item test corpus (NFR-09). It is weaker for formats outside it (OQ-05).

None of this changes a position in *Constraints_Essay.md*: the Security and Legal positions there are the ones applied here.

Implementation status. No application code exists yet; the build starts at M0 (2027-01-20). This statement audits the design and the repository as they stand, and it is re-run against the code at M1 and M6 (Test_Plan.md, Section 7).

1. Privacy Summary

Every item below crosses an arrow on the D0 to D2 diagrams (I1–I7, Fig D2-1 to D2-5).

Storage terms used in the table:

- **DB:** Concentrate AI's managed PostgreSQL 16, encrypted at rest by the provider, reached only over TLS by the Server's database role.
- **Server role:** the API service account. No team member queries production data directly after M7.
- **Proposed** retention periods have not yet been decided by the team. Allison Oh and Aditya Pawar confirm them with Todd Liebermann by M0 (2027-01-20), and a scheduled deletion job enforces them (task T4).

Data item	Source	Purpose	Consent	Storage	Access	Retention
Brief: `budget`, `latency_ms`, `task_description`	Product manager, S1 → E1 (I1, I2)	Build prompts; rank against the ceilings (REQ-01)	Client company's service agreement with Concentrate AI; S1 notice that the text, with emails and phone numbers removed, goes to the vendors their reviewer approved	DB `runs.brief` (jsonb)	Server role; users of the same client company through E2/E5 (`client_id` filter, NFR-08)	Proposed: 12 months after the run, then deleted
Sanitized sample prompts	Derived from `task_description` by `PromptSanitizer` (I3)	Benchmark calls to vendors	IT reviewer's vendor approval (US-04, REQ-04), linked to each vendor's retention policy (REQ-07)	Not stored by us; held in memory for the run; redacted from logs (EC-45)	Server process; approved vendors under their own API terms	Ours: end of run. Vendor's: per its published policy, shown on S4
Completion text and grader prompts	Vendor responses (I3)	Grading quality (A1)	Same approval; grader is always an approved vendor	Memory only; never written to the DB or logs	Server process	End of run

Data item	Source	Purpose	Consent	Storage	Access	Retention
Usage log: model, kind, outcome, tokens, latency, cost, timestamps	Server (`logVendorCall`)	Metering spend (CON-01, REQ-11); debugging	No personal data; covered by service agreement	DB `vendor_calls` (no text fields)	Server role; platform operator	Proposed: 13 months (one billing year)
Report and entries: scores, reasoning, ranks, selection	A2, E8, E9	Showing and keeping the recommendation (REQ-02, REQ-12)	Service agreement	DB `reports`, `report_entries`	Same client company's users; solutions engineers through E10	Proposed: 12 months, or earlier on the client's request
Review notes (≤ 500 characters)	Solutions engineer, E8	Explaining a manual reorder (REQ-09)	Staff policy (proposed): notes must not contain client personal data	DB `report_annotations`	Same as the report	With the report
Vendor approval: vendors, `approved_at`, `expires_at`, `reminder_sent_at`	IT reviewer, E4	Record of consent for vendor sharing	Is the consent record itself	DB `vendor_approvals`	Server role; client's reviewer and PMs (E11)	While the account is active, plus 12 months (proposed) as an audit trail
User record: IdP subject, `client_id`, `role`, `email`	Identity provider at first sign-in (I5)	Authentication, roles, notifications	Sign-in through the client's own identity provider	DB `app_users`; no passwords stored anywhere	Server role	Proposed: deleted 30 days after the account is removed
Access token (JWT)	Identity provider (I5)	Authenticating each request	Sign-in	Browser memory only (not local storage, NFR-10); never stored or logged by the Server	Browser tab; Server verifies only	Token lifetime set at the IdP (proposed 60 minutes)
Notifications: recipient, type, payload (report or vendor IDs)	Server outbox (I6)	Approval, review and rate-limit messages	Service agreement; in-app copy always available	DB `notifications`; email address passed to the email provider; ops webhook carries vendor and run IDs only, no client data	Recipient; platform operator	Proposed: 90 days
Application logs: request ID, run ID, route, status, latency, errors	Server (pino)	Debugging and incident response	No personal data after redaction of prompt, completion and `authorization`	Hosting platform log service	Team (until M7), then Concentrate AI operators	Proposed: 30 days
Platform access logs: IP address, user agent	Hosting platform	Platform security	Platform terms	Hosting platform only; never copied into our DB	Concentrate AI platform admins	Platform setting (proposed ≤ 30 days)
Client company record: name, `requires_se_review`	Concentrate AI account setup	Tenant boundary; review setting	Service agreement	DB `clients`	Server role	Life of the account
Vendor and model catalog, prices	Public vendor pages and configuration	Ranking and cost (REQ-07, REQ-11)	Public data	DB `vendors`, `models`; `config/server.yaml`	Everyone through E7	Kept; models soft-deleted
Test data	Seed script (Test_Plan.md, Section 5)	Testing	Synthetic only; the PII corpus contains invented values, never real people	Repository and test databases	Team	Test databases destroyed at M7

Fields we chose not to collect:

- user names, phone numbers or job titles (the IdP subject and email are enough);
- passwords (the IdP handles sign-in);
- completion text and raw, unsanitized prompts in storage;
- IP addresses in our database.

No field has been removed after being designed in, because none has been designed in without a purpose. This table is re-checked against the schema at M0, and any column it cannot justify is dropped.

When the project ends (M7, 2027-04-30):

- Pilot data in production belongs to Concentrate AI under its customer agreements. At handoff, Concentrate AI decides whether to keep or delete it.
- Team members' production access is revoked the same day.
- Development and staging databases are destroyed.
- The repository contains only synthetic test data.

2. Security Summary

Common gap	How the design closes it
Default credentials	No application accounts or passwords exist; sign-in is OIDC only (D2 2.5). Users are created from the IdP subject, never seeded with a password. The production database password is generated by the managed platform and kept in its secret store. Local development reads its database password from an untracked `.env` file.
Unauthenticated endpoints	E1–E12 all require a bearer JWT and check the role with `requireRole`. Another company's data returns 404 (NFR-08). The only open route is `GET /health`, which returns `{status: "ok"}` and nothing else. TC-20.1 tests all 96 role × endpoint × token combinations.
Secrets in source control	Vendor API keys, the database URL and webhook URLs live in the hosting platform's secret store (D2 2.7); `config/server.yaml` holds no secrets. `.env` is in `.gitignore`. gitleaks runs in CI on every push and fails the build on a finding (TC-22.2).

Mechanisms:

- **Authentication:** OIDC with RS256 JWTs verified by `jose`. Signature, `iss`, `aud` and `exp` are checked with 30 s clock skew, and JWKS keys are cached for 10 minutes.
- **Token lifetime:** set at the IdP, proposed at 60 minutes, renewed by silent refresh.
- **HTTPS:** TLS 1.2 or later everywhere, plus TLS to the database (NFR-10).
- **Rate limiting:**
  - each client company may have at most 3 active runs and 20 runs per hour (NFR-07);
  - each vendor has its own concurrency limiter (A1);
  - repeated submissions return the existing run through the `Idempotency-Key` header (REQ-13).
- **Least privilege (proposed for T3):** the Server's database role has no DDL rights; migrations run under a separate role.
- **Fail closed:** if the approval list cannot be read, the run is refused with 503 (REQ-04).

History scan. On 2026-11-11 we ran gitleaks 8.21.2 over the full history of `AllyOI/model-recommend` (32 commits, of which 20 contain scannable text changes). It found **0 leaks**. A second regex search of `git log -p` for API-key, token, private-key and `password=` patterns also found 0 matches. Nothing needed fixing, because no code or configuration has been committed yet. The same scan runs in CI from M0.

Self-audit:

Question	Answer
Can anyone sign in with a default or shared password?	No. There are no passwords; every user comes from the IdP.
Can any endpoint that reads or changes data be called without a token?	No. Only `/health` is open, and it returns no data.
Is any secret in the repository or its history?	No: gitleaks and the regex search both found 0 matches on 2026-11-11.
Can one client company read another's data?	No. Every query filters by the token's `client_id`, and cross-company reads return 404 (TC-12.3).
Can client text leave the system unredacted, or reach an unapproved vendor?	Not by design: the sanitizer runs before every vendor call and the approval check fails closed (TC-04, TC-21). The rule set's limits are stated in the introduction.
Do logs contain prompts, completions or tokens?	No. pino redacts those paths (TC-21.2).
Is traffic encrypted in transit?	Yes. TLS 1.2+ only, checked with testssl.sh (TC-22.1).
Are dependencies checked for known vulnerabilities?	Planned: `npm audit --omit=dev` in CI from M0, with high and critical findings blocking a merge.
Who has production access, and when does it end?	The two team members until M7, then only Concentrate AI staff.

3. Licensing Summary

No `package.json` exists yet, so this table is built from the planned stack (D1 Part 4, Tech Spec Section 4). Versions and licenses were read from the npm registry and each project's repository on 2026-11-11. At M0 it is regenerated from `package-lock.json` with `license-checker`.

Project license: MIT. The MIT text and copyright line go in `LICENSE`. MIT is compatible with every permissive row below. The copyleft rows are tools we run, not code we link or ship, so they place no obligation on our source.

Name	Version	SPDX license	Type	Obligation on us
Node.js	22 LTS	MIT	Permissive	Keep notice if redistributed
Fastify	5.12.8	MIT	Permissive	Keep copyright notice
zod	4.6.7	MIT	Permissive	Keep copyright notice
p-limit / p-retry	7.3.3 / 8.0.1	MIT	Permissive	Keep copyright notice
openai (SDK)	7.55.0	Apache-2.0	Permissive	Keep license and NOTICE; state changes if modified
@anthropic-ai/sdk	1.8.0	Apache-2.0	Permissive	Same as above
jose	6.2.17	MIT	Permissive	Keep copyright notice
Kysely / pg / node-pg-migrate	0.29.8 / 8.23.1 / 9.0.0	MIT	Permissive	Keep copyright notice

Name	Version	SPDX license	Type	Obligation on us
pino	10.4.0	MIT	Permissive	Keep copyright notice
PostgreSQL	16	PostgreSQL	Permissive	Keep notice; used as a service
React / Vite	19.3.1 / 8.3.8	MIT	Permissive	Keep copyright notice in the built bundle’s license file
vitest / @playwright/test	5.1.0 / 1.65.0	MIT / Apache-2.0	Permissive	Development only; not shipped
Docker Engine	27	Apache-2.0	Permissive	Tool only
Toxiproxy / gitleaks	2.x / 8.21.2	MIT	Permissive	Tools only
k6	1.x	**AGPL-3.0-only**	**Copyleft**	Load-test tool run locally and in CI; not linked, modified or offered as a service. No obligation on our code.
testssl.sh	3.2	**GPL-2.0-only**	**Copyleft**	Command-line scanner; not distributed. No obligation.
pandoc	3.1	**GPL-2.0-or-later**	**Copyleft**	Builds our PDFs; its output is not covered. No obligation.
draw.io / Mermaid	24.x / 12.3.0	Apache-2.0 / MIT	Permissive	Tools; the diagrams are our own work
Inter (font)	4.0 (@fontsource 5.3.0)	OFL-1.1	Permissive (font)	May bundle with the Client; keep the OFL text; may not sell the font alone or reuse its name for a modified version
IBM Plex Mono (font)	@fontsource 5.3.0	OFL-1.1	Permissive (font)	Same as Inter
Concentrate AI logo and brand guide	2025 brand guide	LicenseRef-Concentrate-Proprietary	Proprietary	Used in slides with the sponsor’s permission; not committed to the repository or covered by our MIT license
OpenAI and Anthropic APIs	Current	LicenseRef-OpenAI-Terms / LicenseRef-Anthropic-Commercial-Terms	Service terms	Comply with usage and benchmarking terms; no public head-to-head comparisons (CON-04, W-02, OQ-06)
Datasets	None	—	—	The project uses no third-party datasets; all test data is synthetic.

Decision: keep MIT. Run the copyleft tools as separate programs only, and never copy their code into the repository. Keep the Concentrate AI brand assets out of the repository.

4. Attribution List

The same list is in `NOTICE.md` at the repository root.

Libraries and tools:

- Fastify (https://github.com/fastify/fastify)
- zod (https://github.com/colinhacks/zod)
- p-limit (https://github.com/sindresorhus/p-limit) and p-retry (https://github.com/sindresorhus/p-retry)
- openai-node (https://github.com/openai/openai-node)
- anthropic-sdk-typescript (https://github.com/anthropics/anthropic-sdk-typescript)
- jose (https://github.com/panva/jose)
- Kysely (https://github.com/kysely-org/kysely)
- node-postgres (https://github.com/brianc/node-postgres)
- node-pg-migrate (https://github.com/salsita/node-pg-migrate)
- pino (https://github.com/pinojs/pino)
- PostgreSQL (https://www.postgresql.org)
- React (https://github.com/facebook/react)
- Vite (https://github.com/vitejs/vite)
- Vitest (https://github.com/vitest-dev/vitest)
- Playwright (https://github.com/microsoft/playwright)
- k6 (https://github.com/grafana/k6)
- Toxiproxy (https://github.com/Shopify/toxiproxy)
- gitleaks (https://github.com/gitleaks/gitleaks)
- testssl.sh (https://github.com/testssl/testssl.sh)
- draw.io (https://github.com/jgraph/drawio)
- Mermaid (https://github.com/mermaid-js/mermaid)
- pandoc (https://github.com/jgm/pandoc)

Code adapted from tutorials or other repositories: none so far. From M0, any adapted snippet gets a source comment in the file and a line here.

Datasets: none. Test data is generated by our seed script. The 200-item PII test corpus is invented values, so no real people are involved.

Non-code assets:

- Diagrams (D0–D2, Gantt, WBS): drawn by the team in draw.io and Mermaid, MIT with the rest of the repository.

- Inter font: Rasmus Andersson, OFL-1.1.
- IBM Plex Mono font: IBM Corp., OFL-1.1. Both fonts appear in the presentation graphics only.
- Concentrate AI logo and brand guide: © Concentrate AI Inc., used with the sponsor's permission, and not in the repository.
- No icon sets or stock images are used.

5. AI-Use Disclosure

Syllabus policy: "Generative AI tools may be used for drafting and code assistance but not for the design decisions or written analysis that are assessed in this course."

Before mid-October 2026. The ideas were the team's: the project concept, the constraints, the user stories, and the D0/D1 components and data model. Aditya Pawar used Claude in separate sessions to structure those ideas into documents and draft the wording (rows 1–4). Allison Oh's professional biography was written without AI tools.

Tool	Used by	Task	Column	How verified
Claude (Anthropic, separate sessions)	Aditya Pawar	Structured the team's ideas and drafted the Constraints Essay (Week 3) and User Stories and Use Cases (Week 4)	Not OK without disclosure	Drafts reviewed and edited by the team before committing
Claude (separate sessions)	Aditya Pawar	Structured the team's component and interface ideas and drafted D0 High-Level Design (2026-10-02)	Not OK without disclosure	Drafts reviewed and edited by the team before committing
Claude (separate sessions)	Aditya Pawar	Structured the team's data-model and algorithm ideas and drafted D1 Detailed Design (2026-10-08)	Not OK without disclosure	Drafts reviewed and edited by the team before committing
Claude (separate sessions)	Aditya Pawar	Drafted Aditya's professional biography, the Team Contract and the Project Description from the team's notes	Generally OK	Reviewed and edited before committing
Claude (Anthropic, Claude app)	Aditya Pawar	Drafted D2 sections and redrew Fig D2-1 to D2-5 (A7)	Not OK without disclosure	Aditya reviewed each section and figure against D0/D1 before committing
Claude	Aditya Pawar	Drafted peer-review feedback on the Kraft team's D2	Not OK without disclosure	Read against the other team's document before sending
Claude	Aditya Pawar	Drafted the A8 task list, milestones, timeline and effort matrix, plus the Gantt and WBS sources	Not OK without disclosure	Dates and owners checked against the course calendar and the team contract
Claude	Aditya Pawar	Drafted the Requirements Document and Technical Specification (A9), including requirement wording and the traceability matrix	Not OK without disclosure	A script confirmed all 33 REQ/NFR/CON IDs appear in the matrix; read and edited by Aditya
Claude	Aditya Pawar	Drafted the Test Plan (A10)	Not OK without disclosure	Script confirmed every TC group TC-01 to TC-29 has cases; read by Aditya
Claude	Aditya Pawar	Drafted this statement; ran the gitleaks scan; looked up licenses on npm	Not OK without disclosure (drafting); Generally OK (scan, lookup)	Scan output and npm results are reproducible; Allison (documentation owner) reviews the text before submission
Claude	Aditya Pawar	Slide wording and branded graphics for the CS 5001 presentation	Generally OK	Checked on screen before presenting
Claude	Aditya Pawar	PDF formatting, README updates, repository reorganization, GitHub uploads	Generally OK	Rendered PDFs and the repository checked visually

Each of us signs below only if it is true. If either of us cannot, we say so in this section instead of signing.

- I confirm that the architecture, data model, priorities and design rationale in this project are the team's own. — Allison Oh, 2026-11-11
- I confirm that the architecture, data model, priorities and design rationale in this project are the team's own. — Aditya Pawar, 2026-11-11